

Checklist

Create a Security Program

1. Lay the Groundwork

- Define the purpose and goals of the security program.
- Identify business objectives the security program must support.
- Select a cybersecurity framework to guide the program.
- Consider using the **NIST Cybersecurity Framework (CSF) 2.0**.
- Organize security activities around the **Identify, Protect, Detect, Respond, Recover, and Govern functions**.
- Identify relevant compliance, legal, regulatory, and industry requirements.
- Avoid blindly applying standards that do not fit the organization.
- Document the initial scope of the security program.

2. Establish Security Teams and Responsibilities

Executive Team

- ☐ Assign executive security leadership, such as a **CIO or CISO**.
- ☐ Give security leadership sufficient authority to make organization-wide decisions.
- ☐ Establish long-term security goals.
- ☐ Identify corporate risks requiring executive attention.
- ☐ Allocate security funding and resources.
- ☐ Approve major security milestones.

Risk Team

- ☐ Establish responsibility for security risk assessment.
- ☐ Identify and document business and cybersecurity risks.
- ☐ Select a risk framework where appropriate, such as:
 - ☐ NIST Risk Management Framework (RMF)
 - ☐ OCTAVE

- ☐ Coordinate cybersecurity risk with broader enterprise risk management.

Security Team

- ☐ Assign responsibility for daily security operations.
- ☐ Establish asset-management responsibilities.
- ☐ Establish threat and vulnerability assessment processes.
- ☐ Monitor the environment for attacks and suspicious activity.
- ☐ Establish risk-management activities.
- ☐ Provide security awareness and technical training.
- ☐ Define specialist roles where needed, including:
 - ☐ Network security
 - ☐ Security operations
 - ☐ Security engineering
 - ☐ Application security
 - ☐ Offensive security

Auditing Team

- ☐ Establish an independent or semi-independent auditing function.
- ☐ Review security processes and controls for gaps.
- ☐ Verify that required security tasks and milestones are completed.
- ☐ Document audit findings.
- ☐ Track remediation of audit issues.

Cross-Team Coordination

- ☐ Define security responsibilities across departments.
- ☐ Establish regular communication between security, IT, legal, HR, finance, and leadership.
- ☐ Combine roles where necessary for smaller organizations.
- ☐ Plan to separate specialized roles as the organization grows.

3. Determine the Baseline Security Posture

Policies and Procedures

- ☐ Inventory existing security policies.

- ☐ Inventory security procedures.
- ☐ Inventory incident-response plans and playbooks.
- ☐ Identify missing or outdated documentation.

Endpoints

- ☐ Inventory desktops.
- ☐ Inventory laptops.
- ☐ Inventory servers.
- ☐ Record operating-system and software versions.
- ☐ Record deployment or implementation dates.
- ☐ Identify unsupported or legacy systems.

Licensing and Certificates

- ☐ Inventory software licenses.
- ☐ Record license renewal dates.
- ☐ Inventory SSL/TLS certificates.
- ☐ Record certificate expiration dates.
- ☐ Create reminders for upcoming renewals.

Internet Footprint

- ☐ Inventory public domains.
- ☐ Inventory mail servers.
- ☐ Inventory public-facing applications.
- ☐ Inventory DMZ systems.
- ☐ Document cloud infrastructure.
- ☐ Identify externally accessible services.

Network Infrastructure

- ☐ Inventory firewalls.
- ☐ Inventory routers.
- ☐ Inventory switches.
- ☐ Inventory wireless access points.
- ☐ Inventory IDS/IPS systems.
- ☐ Document important network traffic flows.

Logging and Monitoring

- ☐ Identify systems currently generating security logs.
- ☐ Confirm logs are centrally available where possible.
- ☐ Determine appropriate log-retention periods.
- ☐ Identify monitoring gaps.
- ☐ Define alerting responsibilities.

Ingress and Egress

- ☐ Document internet service providers.
- ☐ Record ISP account details in an approved secure location.
- ☐ Document external IP addresses.
- ☐ Identify all network ingress points.
- ☐ Identify all network egress points.

Vendors

- ☐ Inventory third-party vendors.
- ☐ Identify vendors with remote access.
- ☐ Record primary vendor contacts.
- ☐ Identify systems and data accessible to each vendor.
- ☐ Review vendor security risks.

Applications

- ☐ Inventory critical business applications.
- ☐ Identify internally maintained applications.
- ☐ Identify third-party/SaaS applications.
- ☐ Assign application owners.
- ☐ Identify applications supporting critical business functions.

4. Assess Threats and Risks

Identify Scope, Assets, and Threats

- ☐ Define which systems, departments, locations, and data are included in each assessment.

- ☐ Identify critical assets.
- ☐ Identify sensitive data.
- ☐ Identify business-critical services.
- ☐ Identify industry-specific threats.
- ☐ Identify common threats, including:
 - ☐ Malware
 - ☐ Ransomware
 - ☐ Phishing
 - ☐ Credential attacks
 - ☐ Remote exploitation
 - ☐ Insider threats
 - ☐ Distributed denial-of-service attacks
- ☐ Review relevant threat-intelligence sources.
- ☐ Review the OWASP Top 10 where applicable.
- ☐ Review CIS Controls.
- ☐ Review relevant cloud-security guidance.
- ☐ Review sector-specific ISAC information where available.

Assess Risk and Impact

- ☐ Conduct internal vulnerability scans.
- ☐ Conduct external vulnerability scans.
- ☐ Review firewall rules.
- ☐ Review user permissions.
- ☐ Review authentication controls.
- ☐ Review asset-management records.
- ☐ Evaluate the likelihood of each identified risk.
- ☐ Evaluate the potential impact of each risk.
- ☐ Document the threat.
- ☐ Document the vulnerability.
- ☐ Document the affected asset.
- ☐ Document the potential consequence.

Risk Calculation

- ☐ Assign a likelihood rating from 1–5.
- ☐ Assign an impact rating from 1–5.
- ☐ Calculate **Risk = Likelihood × Impact**.

- ☐ Classify the resulting risk level.
- ☐ Record the result in the risk register.

5. Decide How Each Risk Will Be Treated

Risk Avoidance

- ☐ Determine whether the risky activity or process can be eliminated.
- ☐ Stop collecting or processing unnecessary sensitive information where possible.

Risk Remediation

- ☐ Patch vulnerable systems.
- ☐ Close unnecessary ports.
- ☐ Strengthen firewall rules.
- ☐ Harden endpoint configurations.
- ☐ Remove unnecessary services.
- ☐ Correct insecure permissions.

Risk Transfer

- ☐ Identify risks that can appropriately be transferred.
- ☐ Review outsourcing options where appropriate.
- ☐ Review cyber-insurance options where applicable.
- ☐ Confirm transferred risks are contractually documented.

Risk Acceptance

- ☐ Accept risk only when avoidance, remediation, or transfer is impractical.
- ☐ Document the business justification.
- ☐ Obtain approval from the appropriate risk owner or executive.
- ☐ Document compensating controls.

- ☐ Establish an expiration or review date.
- ☐ Reassess accepted risk at least annually or when conditions change.

6. Monitor Risk

- ☐ Maintain a formal risk register.
- ☐ Assign an owner to each risk.
- ☐ Record existing controls.
- ☐ Record planned treatment actions.
- ☐ Record due dates.
- ☐ Record residual risk.
- ☐ Review high-risk items regularly.
- ☐ Schedule quarterly or annual risk-review meetings as appropriate.
- ☐ Review risks after major organizational or technical changes.
- ☐ Update risk ratings when conditions change.
- ☐ Integrate risk monitoring with vulnerability management where possible.

7. Establish Governance

Policies

- ☐ Create documented security and risk-management policies.
- ☐ Define how risks are identified.
- ☐ Define how risks are assessed.
- ☐ Define how risks are treated.
- ☐ Define how risks are monitored.
- ☐ Define how risks are reported.
- ☐ Review policies regularly.
- ☐ Update policies when the threat or business environment changes.

Regulatory Compliance

- ☐ Identify applicable laws.
- ☐ Identify applicable regulations.
- ☐ Identify contractual requirements.
- ☐ Identify applicable industry standards.
- ☐ Track regulatory changes.
- ☐ Update policies and controls when requirements change.

Communication and Reporting

- ☐ Define security-reporting channels.
- ☐ Define escalation procedures.
- ☐ Provide regular risk reports to management.
- ☐ Provide appropriate reporting to the board or governing body.
- ☐ Communicate material risks to affected stakeholders.

Training and Awareness

- ☐ Establish employee security-awareness training.
- ☐ Define role-specific security responsibilities.
- ☐ Train staff on reporting suspicious activity.
- ☐ Provide specialized training for technical personnel.
- ☐ Reinforce security and risk awareness regularly.

Continuous Improvement

- ☐ Review lessons learned from incidents.
- ☐ Review lessons learned from audits.
- ☐ Review lessons learned from assessments.
- ☐ Identify control weaknesses.
- ☐ Track corrective actions.
- ☐ Measure whether remediation was effective.
- ☐ Update security goals and processes based on findings.

8. Prioritize Security Work

- ☐ Rank risks from highest to lowest.
- ☐ Address active attacks and urgent threats before routine program work.
- ☐ Consider both likelihood and impact when prioritizing.
- ☐ Consider the business context before following vendor recommendations.
- ☐ Identify low-cost/high-impact security improvements.
- ☐ Prioritize controls that reduce multiple risks.
- ☐ Consider implementation time.
- ☐ Consider staff availability.
- ☐ Consider budget requirements.
- ☐ Consider dependencies between projects.
- ☐ Document why each major initiative received its priority.

9. Create Security Milestones

Tier 1 — Quick Wins

- ☐ Identify changes that can be completed in hours or days.
- ☐ Remove unused endpoints.
- ☐ Disable unused accounts.
- ☐ Patch critical vulnerabilities.
- ☐ Move legacy systems to more secure network segments.
- ☐ Close unnecessary ports.
- ☐ Apply immediately available vendor patches.
- ☐ Remove unnecessary access.

Tier 2 — This Year

- ☐ Plan larger network-routing changes.
- ☐ Implement user security education.
- ☐ Decommission shared accounts.
- ☐ Retire unnecessary services.
- ☐ Replace outdated devices.
- ☐ Complete improvements requiring moderate planning and coordination.

Tier 3 — Next Year

- ☐ Plan major infrastructure changes.
- ☐ Plan major server replacements.
- ☐ Implement mature monitoring capabilities.
- ☐ Improve authentication systems.
- ☐ Plan major cloud transitions where appropriate.
- ☐ Schedule projects that require significant planning or have prerequisites.

Tier 4 — Long Term

- ☐ Plan network redesigns.
- ☐ Plan major software replacements.
- ☐ Plan new facilities or data-center changes.
- ☐ Plan projects dependent on major contracts or renewals.
- ☐ Establish multiyear security goals.

10. Develop Security Use Cases

- ☐ Identify approximately three high-priority attack scenarios to begin with.
- ☐ Include scenarios affecting critical infrastructure.
- ☐ Include scenarios affecting sensitive data.
- ☐ Consider ransomware.
- ☐ Consider DDoS attacks.
- ☐ Consider disgruntled employees.
- ☐ Consider insider threats.
- ☐ Consider data exfiltration.
- ☐ Identify the assets involved in each scenario.
- ☐ Map attacker actions.
- ☐ Map defensive controls.
- ☐ Map detection and monitoring opportunities.
- ☐ Convert mature use cases into security playbooks.

11. Map Attacks to the Cyber Kill Chain

Reconnaissance

- ☐ Identify how an attacker could research the organization.
- ☐ Monitor exposure of employee information.
- ☐ Monitor exposed email addresses or credentials.
- ☐ Reduce unnecessary public technical information.

Weaponization

- ☐ Track threats and exploit techniques being used against similar organizations.
- ☐ Maintain threat-awareness processes.
- ☐ Use threat information to tune defensive controls.

Delivery

- ☐ Strengthen email security.
- ☐ Filter unnecessary or dangerous attachment types.
- ☐ Use malware-blocking technologies.
- ☐ Block malicious domains.
- ☐ Train users to adopt a “trust but verify” approach.
- ☐ Monitor suspicious downloads and file types.

Exploitation

- ☐ Patch endpoints.
- ☐ Disable unnecessary macros.
- ☐ Restrict dangerous file types.
- ☐ Maintain endpoint protection.
- ☐ Monitor proxy and IDS logs for exploitation attempts.

Installation

- ☐ Maintain tested backups.
- ☐ Keep critical backups offline or otherwise protected from ransomware.

- ☐ Apply application-control or filesystem restrictions where appropriate.
- ☐ Monitor unexpected encryption or file changes.

Command and Control

- ☐ Monitor outbound network traffic.
- ☐ Block known malicious IP addresses.
- ☐ Use DNS filtering or sinkholing where appropriate.
- ☐ Alert on connections to known command-and-control infrastructure.

Actions on Objectives

- ☐ Monitor unusual file-access patterns.
- ☐ Detect mass file modification or encryption.
- ☐ Monitor suspicious access to sensitive data.
- ☐ Create alerts for abnormal filesystem changes.
- ☐ Maintain controls to detect data exfiltration.

12. Conduct Tabletop Exercises and Drills

Preparation

- ☐ Select a realistic incident scenario.
- ☐ Define the goals of the exercise.
- ☐ Assign a facilitator or moderator.
- ☐ Select participants from relevant departments.
- ☐ Include representatives from:
 - ☐ Security
 - ☐ IT
 - ☐ Management
 - ☐ HR
 - ☐ Legal
 - ☐ Finance

- ☐ Physical security
- ☐ Communications/marketing
- ☐ Other affected departments
- ☐ Assign an evaluator or note-taker.

Exercise Materials

- ☐ Prepare a scenario handout.
- ☐ Provide space or materials for notes.
- ☐ Provide current incident-response runbooks.
- ☐ Provide relevant policies and procedures.
- ☐ Prepare a list of tools and external services.
- ☐ Prepare contact information for key parties.

During the Exercise

- ☐ Present the scenario.
- ☐ Ask “what if” questions.
- ☐ Introduce additional complications when useful.
- ☐ Encourage participants to challenge assumptions.
- ☐ Follow the applicable runbook or playbook.
- ☐ Record decisions.
- ☐ Record unclear responsibilities.
- ☐ Record missing processes or tools.

After the Exercise

- ☐ Ask what went well.
- ☐ Ask what could have gone better.
- ☐ Identify missing services or processes.
- ☐ Identify unnecessary or irrelevant steps.
- ☐ Document corrective actions.
- ☐ Assign owners to corrective actions.
- ☐ Establish deadlines.
- ☐ Update the response plan before the next exercise.

Technical Drills

- ☐ Test backup restoration.
- ☐ Test disaster-recovery procedures.
- ☐ Test failover to secondary systems.
- ☐ Test selected incident-response procedures.
- ☐ Validate that security controls operate as expected.

13. Expand the Team and Skillsets

- ☐ Identify technical skill gaps within the security team.
- ☐ Create a home lab or provide access to a training lab.
- ☐ Encourage hands-on security practice.
- ☐ Use safe environments for testing new tools and techniques.
- ☐ Encourage participation in Capture the Flag (CTF) competitions.
- ☐ Use CTFs to improve technical and teamwork skills.
- ☐ Identify open-source projects employees can contribute to.
- ☐ Create internal projects for skills development.
- ☐ Encourage participation in security conferences and local meetups.
- ☐ Encourage staff to volunteer, speak, sponsor, or train at industry events.
- ☐ Establish mentoring opportunities.
- ☐ Encourage staff to act as both mentors and mentees.
- ☐ Evaluate communication and collaboration skills in addition to technical skills.
- ☐ Build a culture of continuous learning.

14. Program Completion Review

- ☐ Security leadership and responsibilities are defined.
- ☐ Critical assets are inventoried.
- ☐ The current security baseline is documented.
- ☐ Major threats are identified.
- ☐ Risks are assessed and recorded.
- ☐ High risks have documented treatment plans.
- ☐ A risk register is maintained.
- ☐ Security governance is established.

- ☐ Policies and procedures are documented.
- ☐ Compliance obligations are identified.
- ☐ Security work is prioritized.
- ☐ Short-, medium-, and long-term milestones are established.
- ☐ Key attack scenarios have use cases or playbooks.
- ☐ Logging and monitoring support major security scenarios.
- ☐ Incident-response exercises are conducted.
- ☐ Exercise findings are tracked to completion.
- ☐ Security training is ongoing.
- ☐ The security program is periodically reassessed.
- ☐ Improvements are continuously incorporated into the program.